

Automated Dynamic Analysis of Ransomware: Benefits, Limitations and use for Detection

ABSTRACT

Recent statistics show that in 2015 more than 140 millions new malware samples have been found. Among these, a large portion is due to ransomware, the class of malware whose specific goal is to render the victim's system unusable, in particular by encrypting important files, and then ask the user to pay a ransom to revert the damage. Several ransomware include sophisticated packing techniques, and are hence difficult to statically analyse. We present *EldeRan*, a machine learning approach for dynamically analysing and classifying ransomware. *EldeRan* monitors a set of actions performed by applications in their first phases of installation checking for characteristics signs of ransomware. Our tests over a dataset of 582 ransomware belonging to 11 families, and with 942 goodware applications, show that *EldeRan* achieves an area under the ROC curve of 0.995. Furthermore, *EldeRan* works without requiring that an entire ransomware family is available beforehand. These results suggest that dynamic analysis can support ransomware detection, since ransomware samples exhibit a set of characteristic features at run-time that are common across families, and that helps the early detection of new variants. We also outline some limitations of dynamic analysis for ransomware and propose possible solutions.

1. INTRODUCTION

In recent months, numerous Internet users have been victims of cyber-attack campaigns based on extortion mechanisms [3], [45]. *Ransomware* has emerged as one of the most diffi-

cult scareware¹ to defend from, as it might be computationally infeasible to revert ransomware's damage [37]. There are two basic types of ransomware available in the wild: the first one, *locker-ransomware*, is designed to lock the victims' computer, to prevent them from using it; the second one, and most common nowadays, is *crypto-ransomware*, which encrypts personal files to make them inaccessible to its victims. In both cases, users are forced to pay a ransom to regain access either to their data (assuming no backup mechanism is in place) or system. Ransomware has featured prominently in the media, in particular when in 2014 a Police Department's computer system was infected by *Cryptowall* [9].

Many victims feel their data are so important that they have to pay the ransom. For example, when in 2012 Symantec was able to dismantle a Command and Control (C&C) network used by the *CryptoDefense* ransomware family, the follow-on study showed that 2.9% of victims, out of 68,000 unique infections, appeared to have paid the ransom. Extortion mechanisms, therefore, generate significant revenue for the attackers. For *CryptoWall* version 3, statistics account for an estimated total \$325 million in damages in the US alone [8]. Note that the average ransom request amounts to \$300 [24], and the preferred payment method is through Bitcoins, due to their untraceable properties. Anti-virus (AV) vendors strive to keep the pace with sophisticated malware variants. In fact, signature-based mechanisms are prone to being easily deceived, especially when new variants are spread. For example, according to [3], out of the 3,000 unique analysed exploit kits, which are one of the main vectors of ransomware (e.g., around 62% of infections of Angler exploit kit deliver ransomware), only 6% of their signatures were found in VirusTotal. Furthermore, the average detection of these signatures was very low, with usually less than ten engines (out of around 60) able to detect them. Furthermore, current ransomware implement very sophisticated packing techniques to evade detection, e.g. obfuscated API calls [14], rendering the static analysis (e.g., of import tables) useless. As signature-based AVs are easily evaded, e.g. by the appearance of new variants, it is fundamental to exploit alternative approaches based on dynamically analysing behaviours. In particular, machine learning has been widely applied in research to classify malware, as an alternative to signature-based approaches [1], [20], [28].

In this paper, we propose *EldeRan*, a machine learning approach to classify ransomware based on their early actions. The underlying assumptions of this work are based on the observation that ransomware contain unique dynamic features and, to stop their spread, it is crucial to detect new variants during their first appearance. To this end, EldeRan firstly selects the relevant features that characterize the ransomware behaviour, and then classify each newly-installed application on a user PC through a machine learning algorithm as to perform detection without relying on classical heuristic or signature-based techniques. The goal of this work is to understand whether ransomware can be identified, with a high degree of accuracy, using a limited number of characteristic features and before infecting victims. Furthermore, EldeRan provides an automatic way for creating signatures for new variants of ransomware families. EldeRan complements well AVs signature-based mechanisms, as it can be used to identify cases where AVs may have missed new, or unknown, ransomware families. The main contributions of this paper are:

We propose EldeRan, a framework to identify the most significant ransomware dynamic features, and use them to detect ransomware. Through the Mutual Information criterion, we have identified the most relevant dynamic features amongst a large set of considered ones. EldeRan exploits a relatively small set of features without reducing the performance of the machine learning classifier. By following this approach, EldeRan is also well suited to detect new ransomware families.

We have evaluated the accuracy of the Regularized Logistic Regression by comparing it against other machine learning classifiers, namely the Support Vector Machine (SVM) and Naive Bayes. We found that the Logistic Regression outperforms Naive Bayes and it is competitive with respect to the SVM. Moreover, the Logistic Regression is easy to train and adapt compared to the SVM. The regularization technique applied to the Logistic Regression helps the classifier to generalize better to unseen samples by preventing overfitting.

We compare the classification results with those of VirusTotal: EldeRan's average error rate is 2.4% while that of VirusTotal is 5.6%, and EldeRan achieves a remarkable 96.3% detection rate. We also tested the ability of EldeRan to detect new families of ransomware, obtaining an average detection rate of 93.3%.

EldeRan: CLASSIFICATION OF RANSOMWARE

In this section we discuss our approach, and motivate the selection and use of features to detect ransomware.

3.1 System Design

EldeRan is based on the observation that ransomware samples typically perform some actions that are unique, or significant, with respect to those performed by goodware ones. Therefore, EldeRan is focused on deriving the most important features of ransomware in its early phases. Figures 1 and 2 show, respectively, the design of our proposed system in the analysis and detection phases. In detail, EldeRan firstly dynamically analyses in a sandboxed environment (see Fig. 1) the traces of samples coming from two datasets of ransomware and goodware. From these datasets, EldeRan retrieves, and analyses, the following classes of features: (i) Windows API calls (i.e., the traces of invocations of native functions and Windows API calls), (ii) Registry Key Operations (in particular, the read, open, write, and delete operations), (iii) File System Operations (in particular, the read, open, write, and delete operations), (iv) the set of file operations performed per File Extension, (v) Directory Operations (the set of operations performed on directories, in particular the enumeration and creation), (vi) Dropped Files (i.e., the set of files that are dropped by an application during installation), and (vii) Strings (the strings embedded in the binary). All the features, but the last ones (Strings) are collected while dynamically analysing the ransomware. After this monitoring phase, a feature selection algorithm is applied to select the most relevant ones. Finally, the matrices containing these features are used in a Regularized Logistic Regression classifier, which returns “ransomware” or “goodware” for, respectively, a ransomware or a good application. The classifier is also run online on user PCs to classify new samples, coming from genuine (compromised) website or from various infection vectors (see Fig 2). Note that while the training set is analysed offline, and its classification is done *una tantum* on a sandboxed environment and requires few minutes only, new applications are classified at run-time through an online classifier, which is very fast and can be run on user PCs.

3.2 Feature Selection and Classification

The machine learning component of EldeRan consists of two phases: feature selection and classification. For the first one, we have used the Mutual Information criterion [7], which allows us to select the most discriminating features for ransomware and goodware from the features gathered in the sandbox. Then, for the classification (decision) problem, EldeRan uses a Regularized Logistic Regression classifier.

Feature Selection. Feature selection is a procedure that enables reducing the number of features to build simpler machine learning algorithms, by shortening the training (and prediction) time, and, in many cases, to prevent overfitting. Even if these techniques are not always used in machine learning approaches to detect malware [20, 28], in our opinion they are a key element to make the algorithm more efficient and achieve a better performance, as we will show in Sect. 5. In EldeRan, for each feature, we consider only the presence or absence of that particular feature. Hence, for these binary features, the Mutual Information criterion is a good method to select the most relevant ones, since it